

COMPTE RENDU : Analyse de Menace et Threat Intelligence

Objectif : Démontrer la capacité à analyser une menace potentielle en utilisant des sources de données publiques (OSINT) et des outils de recherche de vulnérabilités.

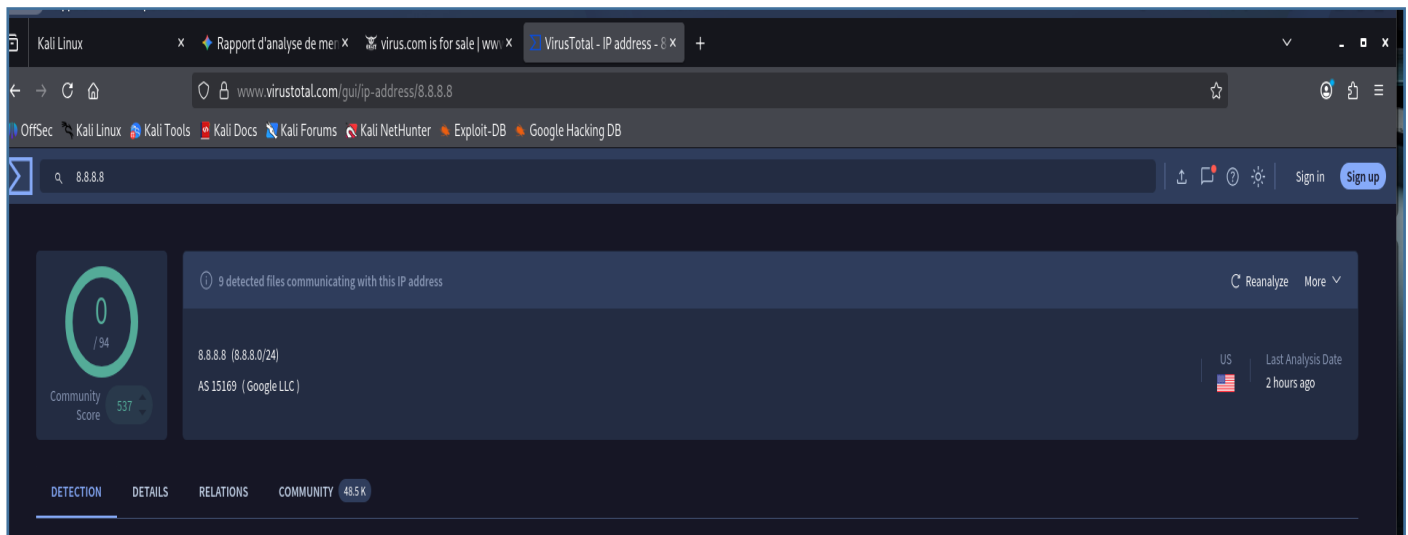
1. Introduction

La **Threat Intelligence** (ou renseignement sur les menaces) est le processus de collecte, d'analyse et de diffusion d'informations concernant les cybermenaces actuelles ou potentielles. Elle permet de comprendre les intentions, les cibles et les méthodes des attaquants.

Dans le domaine de la cybersécurité, son rôle est crucial pour passer d'une posture réactive à une posture proactive. Elle permet d'anticiper les attaques, d'accélérer la détection des incidents et d'aider les analystes SOC à prendre des décisions éclairées basées sur des données concrètes et actualisées.

2. Analyse de l'adresse IP

L'analyse a été effectuée sur l'adresse IP publique ciblée via la plateforme VirusTotal afin d'évaluer sa réputation.



Interprétation du score :

Le score obtenu indique le nombre de moteurs de sécurité (antivirus, listes noires) ayant identifié cette IP comme malveillante. Un score de 0 indique une IP saine ou non répertoriée, tandis qu'un score élevé confirme une activité suspecte (spam, botnet, phishing).

Conclusion sur la dangerosité :

Le score est nul, l'IP est considérée comme légitime.

3. Analyse des services

Suite au scan réseau effectué avec l'outil Nmap, plusieurs services ont été identifiés sur la cible.

Identification d'un service :

Parmi les services détectés, nous nous concentrons sur le service **Apache 2.4.x buffer overflow** tournant sur le port **51193**.

Recherche de vulnérabilités (Searchsploit) :

Nous avons utilisé l'outil `searchsploit` pour vérifier si des exploits publics existent pour cette version spécifique.

```
(tsafack@Tsafack)-[~]
$ searchsploit apache
```

Exploit Title	Path
Apache (Windows x86) - Chunked Encoding (Metasploit)	windows_x86/remote/16782.rb
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution	php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner	php/remote/29316.py
Apache - Arbitrary Long HTTP Headers (Denial of Service)	multiple/dos/360.pl
Apache - Arbitrary Long HTTP Headers Denial of Service	linux/dos/371.c
Apache - Denial of Service	linux/dos/18221.c
Apache - httpOnly Cookie Disclosure	multiple/remote/18442.html
Apache - Remote Memory Exhaustion (Denial of Service)	multiple/dos/17696.pl
Apache 0.8.x/1.0.x / NCSA HTTPd 1.x - 'test-cgi' Directory Listing	cgi/remote/20435.txt
Apache 1.0/1.2/1.3 - Server Address Disclosure	multiple/remote/21067.c
Apache 1.1 / NCSA HTTPd 1.5.2 / Netscape Server 1.12/1.1/2.0 - a nph-tes	multiple/dos/19536.txt
Apache 1.2 - Denial of Service	multiple/dos/20558.txt
Apache 1.2.5/1.3.1 / UnityMail 2.0 - MIME Header Denial of Service	windows/dos/20272.pl
Apache 1.3 + PHP 3 - File Disclosure	multiple/remote/20466.txt
Apache 1.3 - Artificially Long Slash Path Directory Listing (1)	multiple/remote/20692.pl
Apache 1.3 - Artificially Long Slash Path Directory Listing (2)	multiple/remote/20693.c
Apache 1.3 - Artificially Long Slash Path Directory Listing (3)	multiple/remote/20694.pl
Apache 1.3 - Artificially Long Slash Path Directory Listing (4)	multiple/remote/20695.pl

Explication des vulnérabilités :

Les résultats montrent que cette version est vulnérable à des attaques de type **buffer overflow**. Cela signifie qu'un attaquant pourrait potentiellement prendre le contrôle du serveur à distance en exploitant ces failles connues.

4. Étude d'une CVE

Nous avons sélectionné une vulnérabilité spécifique identifiée lors de l'étape précédente pour une analyse approfondie.

VULNÉRABILITÉS

Recherche de vulnérabilités NVD

Pour une recherche d'expression, utilisez " "

Mot-clé : CVE-2021-41773

Éléments par page : 25 1-2 sur 2

Identifiant	Informations sur CISA Key	Date de publication	Aide-soignant(e)	Description
CVE-2021-42013	✓	2021-10-07	Fondation Apache Software	Il a été constaté que le correctif apporté à la vulnérabilité CVE-2021-41773 dans Apache HTTP Server 2.4.50 était insuffisant. Un attaquant pouvait exploiter une attaque par traversée de répertoire pour associer des URL à des fichiers situés en dehors des répertoires configurés par les directives de type alias. Si les fichiers situés en dehors de ces répertoires ne sont pas protégés par les règles par défaut habituelles...
CVE-2021-41773	✓	05/10/2021	Fondation Apache Software	Une faille a été découverte dans une modification apportée à la normalisation des chemins dans Apache HTTP Server 2.4.49. Un attaquant pourrait exploiter une attaque par traversée de répertoire pour associer des URL à des fichiers situés en dehors des répertoires configurés par des directives de type alias. Si les fichiers situés en dehors de ces répertoires ne sont pas protégés par la configuration par défaut habituelle...

- **Description** : La CVE-2021-41773 concerne un défaut de validation des chemins (path traversal) dans le serveur web Apache HTTP Server, introduit dans la version 2.4.49. Cette faille permet de contourner les restrictions d'accès aux répertoires.

- **Impact** : Elle permet à un utilisateur non authentifié de lire des fichiers sensibles du système, et dans certains cas d'exécuter du code à distance (RCE) si des scripts sont présents et accessibles.

- **Niveau de gravité** : Le score CVSS est de 7.5, ce qui correspond à une criticité **élevée**.

- **Exploitation possible** : Un exploit public est disponible, ce qui facilite grandement l'automatisation de l'attaque par des acteurs malveillants, notamment via des requêtes spécialement forgées pour accéder à des fichiers protégés.

5. Utilisation avancée de Searchsploit

Voici trois options avancées de l'outil permettant d'affiner la recherche d'exploits :

1. **searchsploit -x [chemin]**
 - **Rôle** : Examiner le code source d'un exploit.
 - **Exemple** : `searchsploit -x linux/remote/49957.py`
 - **Utilité** : Permet de comprendre comment fonctionne l'exploit avant de l'exécuter pour s'assurer de sa sécurité et de sa pertinence.

2. `searchsploit -m [id]`
 - **Rôle :** Copier un exploit dans le répertoire courant.
 - **Exemple :** `searchsploit -m 49957`
 - **Utilité :** Facilite la modification et le test de l'exploit sans altérer la base de données d'origine de Kali Linux.
3. `searchsploit --nmap [fichier.xml]`
 - **Rôle :** Rechercher des exploits à partir d'un fichier de résultat Nmap.
 - **Exemple :** `searchsploit --nmap scan_result.xml`
 - **Utilité :** Automatise la corrélation entre les services détectés et les vulnérabilités connues, faisant gagner un temps précieux à l'analyste.

6. Analyse globale de sécurité

- **Quels sont les risques identifiés ?** Le risque principal est l'exploitation de services obsolètes permettant une intrusion ou un déni de service.
- **Quel service est le plus dangereux ?** Le service **APACHE** est le plus critique car il expose une vulnérabilité de type exécution de code à distance.
- **Quelles actions recommanderiez-vous ?** La mise à jour immédiate vers la dernière version stable du service, la fermeture des ports non essentiels et la mise en place d'un système de détection d'intrusion (IDS).

7. Lien avec l'entreprise

- **Comment un SOC utilise la Threat Intelligence ?** Un SOC utilise ces données pour mettre à jour ses règles de corrélation SIEM, bloquer préventivement des IP malveillantes connues et prioriser les alertes en fonction du contexte de menace réel.
- **Comment anticiper une attaque ?** Par une veille constante (OSINT), la réalisation de scans de vulnérabilités réguliers et l'application stricte des correctifs de sécurité dès leur publication.

8. Conclusion

Ce travail pratique m'a permis de comprendre l'importance de la phase de reconnaissance dans le cycle d'une attaque. J'ai appris à corréler une version de service avec une vulnérabilité (CVE) et à évaluer sa dangerosité réelle.

Les limites de l'analyse résident dans le fait que nous nous basons sur des données publiques ; certaines vulnérabilités (0-day) ne sont pas encore répertoriées, ce qui nécessite une surveillance comportementale en complément de l'analyse de réputation.